

Attaquer Les Applications Web avec Ffuf.

Catégorie : Offensif
Durée Estimée : 5 heures
Difficulté : Easy, Tim 0.

Ils existent de nombreux outils et méthodes à utiliser pour le fuzzing et l'attaq brute-force des repertoires et paramètres. Nous allons ici étudier l'outil ffuf un ou til fiable et très puissant...

Fuzzing Web :

Le terme fuzzing ou test de robustesse fais référence à une technique de test qui consiste à envoyer diverses types d'entrées utilisateur à une interface pour ete dier sa réaction. Pour eviter d'y passer une éternité on utilise des outils auto matisé comme ffuf pour le fuzzing web.
Des listes de mots a tester existent déjà selon nos besoins, la seclists contenant diverses wordlistes utiles pour les repertoires et pages web courantes...
Maintenant commencons à utiliser l'outil il est souvent pré-installé sinon dispo nible via github ou le gestionnaire de paquets apt.

Repertoires et Pages_ Basic Fuzzing :

- -h : pour la page d'aide comme pour tout les outils
- -ic : supprime la veritable pollution lié aux commentaires explicatifs et/ou licenc des wordlistes.
- -w : spécifie le chemin de la wordlist à utiliser pour le fuzzing
- -u : spécifie l'url cible
FUZZ : mot clé qui sera remplacé par chaqun des mots ca indique la position à fuzzer comme le surlignement de Burp Intruder quoi...
- -t 200 : indique le nombre de thread 200 est un veritable ddos qui sera bloqué. On peu evidemment fuzzer les pages et leurs possible extension il faut juste choir la bonne wordlist et bien placer le mot clé.
Exemple pour les extension : /index FUZZ (en combinaison avec extention.
Exemple pour les pages : /FUZZ.php (extention ayant été verifié lol)
- recursion : déclanche l'analyse recursive en gros après avoir trouvé un repertoir il réitère la wordlist sur cette url pour essayer de trouver un sous-repertoir
- recursion-depth 1 : spécifie la profondeur de la recursivité ici 1 donc juste "sous-repertoire" bien sur on peu changer cette valeur
- -v : affiche l'url complète de chaque resultat trouvé
- -e .php : pour spécifier une extension chaque mot sera alors testé avec et sans cette extension... exemple de commande ci-dessous :

```
fgentpathogene@parrot~$ ffuf -w /path/to/wordlist.txt -u Https://Pserver:po
FUZZ -recursion -recursion-depth 1 -e .php -v
```

Nous allons maintenant voir comment utiliser ffuf pour identifier les sous-doma nes...
Ffuf va simplement verifier si differents sites web (sous domaines) existent en con trolant si ils ont des enregistrements DNS publique qui nous rediregerait vers l'a resse IP d'un serveur fonctionnelle :

```
fgentpathogene@parrot~$ ffuf -w /path/to/subdomainwlist.txt -u Http://FUZ
.inlanefreight.com
```